

Meridian Health Partners — IAM Access Governance Package

Identity & Access Management Governance Framework | Prepared by Saleh Abdu

Purpose	Demonstrates an end-to-end IAM access governance framework for a fictional 500-bed healthcare system, covering the full identity lifecycle, periodic access certification, least-privilege role mapping, and segregation-of-duties controls.
Scope	Covers on-prem Active Directory, Azure AD, EHR clinical application access, and the patient portal SaaS platform.
Frameworks referenced	NIST 800-53 (AC family), HIPAA Security Rule (Access Control 164.312(a)), ISO 27001 Annex A.9
Sheets in this workbook	1) Overview 2) JML Lifecycle Process 3) Access Review Tracker 4) Least-Privilege Access Matrix 5) SoD Conflict Matrix
Author note	Built to demonstrate practical IAM governance documentation skills, informed by hands-on SailPoint IdentityIQ provisioning, JML lifecycle, and access certification experience.

Joiner-Mover-Leaver (JML) Lifecycle Process

Defines standard access lifecycle steps, owners, SLAs, and controls

Stage	Trigger Event	Action Required	Responsible Party	SLA (Business Days)	System(s)	Control / Evidence
Joiner	New hire start date confirmed by HR (HRIS record created)	Create AD/Azure AD account; provision baseline access per role profile (least privilege); assign to correct OU/security group	IT Service Desk + Hiring Manager approval	1	Active Directory, Azure AD, EHR	Provisioning ticket + manager approval recorded in ITSM
Joiner	Role-based access requested beyond baseline (e.g., clinical system access)	Manager submits access request; IAM team validates against role matrix; SoD check performed	IAM Analyst	2	EHR, Patient Portal Admin	Access request form + SoD validation log
Mover	Employee transfer / promotion / department change in HRIS	Review existing access; revoke access no longer required; provision new role-based access; re-validate SoD	IAM Analyst + new Manager approval	3	AD, Azure AD, EHR	Access change ticket + before/after access snapshot
Mover	Temporary elevated access needed (e.g., project, on-call)	Time-bound access grant with auto-expiration date set	IAM Analyst	1	AD, Azure AD	Time-bound access ticket with expiration field
Leaver	Termination notice received from HR (voluntary)	Disable account at end of last working day; revoke all system access; transfer/archive data ownership	IT Service Desk (HR-triggered workflow)	Same day	All systems	Termination checklist signed off by HR + IT
Leaver	Involuntary termination / immediate risk	Immediate account disable and access revocation upon HR/Security notification	Security Team + IT Service Desk	Immediate (within 1 hour)	All systems	Emergency revocation log with timestamp
Leaver	Leave of absence > 30 days	Suspend (not delete) account; reassess access on return	IAM Analyst	1	AD, Azure AD	Suspension ticket + reactivation review
Periodic	Quarterly access recertification cycle begins	Manager reviews direct reports' access; confirms or revokes; SoD re-validated	Manager + IAM Analyst (oversight)	10	All systems	Signed access certification report (see Access Review Tracker tab)

Quarterly User Access Review / Certification Tracker

Q2 2026 Certification Cycle — Manager sign-off required for all entries

User ID	User Name	Department	System / Application	Access Level / Role	Last Reviewed	Still Required?	Reviewer Decision	Reviewed By	Notes / Justification
U10231	J. Alvarez	Clinical Ops	EHR - Clinician Module	Standard Clinician	2026-03-15	Yes	Certified	M. Reyes (Mgr)	Active clinician, access matches role
U10232	T. Nguyen	IT	Active Directory - Domain Admin	Privileged Admin	2026-03-15	Yes	Certified	S. Patel (Mgr)	Required for infrastructure support; SoD reviewed
U10233	R. Chen	Finance	EHR - Billing Module	Billing Specialist	2026-03-15	No	Revoke	L. Brooks (Mgr)	Transferred to AP team 02/2026; billing access no longer needed
U10234	K. Osei	Clinical Ops	Patient Portal Admin	Portal Administrator	2026-03-15	Yes	Certified	M. Reyes (Mgr)	Confirmed active in role
U10235	D. Park	IT	EHR - Clinician Module	Standard Clinician	2026-03-15	No	Revoke	S. Patel (Mgr)	IT staff incorrectly granted clinical access during provisioning;
U10236	A. Whitfield	HR	Active Directory - HR Security Group	HR Generalist	2026-03-15	Yes	Certified	J. Coleman (Mgr)	Standard access for role
U10237	M. Delgado	Finance	EHR - Billing Module	Billing Supervisor	2026-03-15	Yes	Certified	L. Brooks (Mgr)	Access matches current role; SoD reviewed, no conflicts
U10238	C. Ibrahim	IT	Azure AD - Global Admin	Privileged Admin	2026-03-15	No	Revoke - Excessive	S. Patel (Mgr)	Orphaned elevated access from prior project; no business
U10239	E. Sato	Clinical Ops	EHR - Clinician Module	Standard Clinician	2026-03-15	Yes	Certified	M. Reyes (Mgr)	Active clinician, access matches role
U10240	F. Romero	Finance	EHR - Billing Module	Billing Specialist	2026-03-15	Yes	Certified	L. Brooks (Mgr)	Access matches current role

Summary

Total Access Reviewed:	10
Certified (No Change):	7
Flagged for Revocation:	3

Role-Based Least-Privilege Access Matrix

Maps job roles to minimum required system entitlements

Role	AD Domain Access	EHR Clinician Module	EHR Billing Module	Patient Portal Admin	Azure AD Admin	Finance System	Notes
Clinician	Standard User	Read/Write	None	None	None	None	Baseline clinical role
Clinical Supervisor	Standard User	Read/Write	None	Read	None	None	Adds portal read for patient oversight
Billing Specialist	Standard User	None	Read/Write	None	None	Read	No clinical access — SoD enforced
Billing Supervisor	Standard User	None	Read/Write/Approve	None	None	Read/Write	Approval rights for billing only
IT Support Analyst	Standard User	None	None	None	Read (Tier 1)	None	No clinical or billing access — SoD enforced
IT/IAM Administrator	Domain Admin	None	None	Admin	Admin	None	Privileged role — quarterly review required, MFA enforced
HR Generalist	HR Security Group	None	None	None	None	None	Access limited to HRIS, not in this matrix
Portal Administrator	Standard User	None	None	Admin	None	None	No clinical/billing access — SoD enforced

Segregation-of-Duties (SoD) Conflict Matrix

Identifies access combinations that create unacceptable risk if held by one user

Access A	Access B	Conflict?	Risk Description	Mitigating Control	Severity
EHR Billing Module - Write	EHR Billing Module - Approve	Yes	Same user could create and approve their own billing transactions, enabling fraud	Approval role restricted to Billing Supervisor tier; quarterly audit of approver vs. preparer logs	High
IT/IAM Administrator	EHR Clinician Module	Yes	IT staff with clinical data access creates unnecessary PHI exposure beyond job function	Access matrix enforces exclusion; flagged automatically in access reviews (see U10235 example)	High
Azure AD Global Admin	Patient Portal Admin	Yes	Single user could both manage identities and directly access/alter patient-facing data	Role split required; privileged access requires dual sign-off for provisioning	High
Billing Specialist	Finance System - Write	No	Standard billing role requires limited finance read access; not a conflict at this tier	Standard least-privilege provisioning; reviewed quarterly	Low
Domain Admin	Any Standard User Application Access	Yes	Privileged admin accounts should not also hold standard day-to-day application access (increases attack surface)	Separate standard user account required for non-admin tasks	Medium